

Information Security Policy

Owner: Mark Stolte, Founder — markstolte02@gmail.com

Applies to: Penny Pilot (mobile app, Supabase backend, Supabase Edge Functions, Plaid integration)

Last reviewed: 2026-07-05

Stage: Pre-launch / active development

Purpose

This policy states Penny Pilot's commitment to protecting the confidentiality, integrity, and availability of user data — principally financial transaction data, bank connection metadata, and account credentials for identity providers — and describes how the more specific policies in this folder implement that commitment.

Scope

Applies to:

- The Penny Pilot mobile/web client (`src/`)
- The Supabase project backing it (Postgres database, Auth, Storage, Edge Functions)
- The Plaid integration (`supabase/functions/plaid-*`)
- Source control, build, and distribution tooling (GitHub, Expo/EAS, App Store Connect, Google Play Console)
- Any future employee, contractor, or agent (human or automated) with access to the above

Does not apply to end users' own devices or bank accounts, which remain under the user's and their financial institution's control.

Organizational structure

Today, Mark Stolte is the founder, sole engineer, and sole operator of every system listed above. He holds the responsibilities that a larger organization would split across a CISO, a data protection officer, an on-call engineer, and IT — this is stated plainly rather than invented as separate roles. As the team grows, this policy will be updated to name additional owners for specific responsibilities (e.g., a security lead, an on-call rotation), and the subordinate policies (particularly Access Control and Employee Offboarding) already describe what changes when that happens.

Principles

1. **Least privilege.** Access to production systems, user data, and vendor secrets is granted only to the person(s) who need it to do their job, and only for as long as they

need it. See [Access Control Policy](#).

2. **Defense of financial data in particular.** Plaid access tokens and bank account metadata are the most sensitive data Penny Pilot holds. They are encrypted at rest with an application-layer key that never leaves the backend, and are never returned to the client. See [Encryption Standards](#) and [Data Classification & Handling](#).

3. **No home-grown credential storage.** Penny Pilot does not implement its own password hashing or storage. User sign-in is delegated entirely to Apple and Google via Supabase Auth. See [Password & MFA Policy](#).

4. **Secrets stay out of the client and out of git.** Plaid's client secret, the Plaid token-encryption key, and the Supabase service-role key exist only as Supabase Edge Function secrets, never as `EXPO_PUBLIC_*` variables and never committed to source control (`.env` is git-ignored; only `.env.example`, with placeholder values, is tracked).

5. **Honesty about current maturity.** Where a control described in a larger company's security program doesn't exist yet at Penny Pilot's current size (a SIEM, a dedicated on-call rotation, background checks, a bug bounty), the relevant policy says so and states the plan for when it will be introduced, instead of describing it as already in place.

Policy set

This policy is the umbrella for:

- [Access Control Policy](#)
- [Password & MFA Policy](#)
- [Data Classification & Handling](#)
- [Encryption Standards](#)
- [Secure Software Development Lifecycle](#)
- [Vulnerability Management](#)
- [Incident Response Plan](#)
- [Business Continuity & Disaster Recovery](#)
- [Logging & Monitoring](#)
- [Vendor Risk Management](#)
- [Employee Offboarding](#)
- [Risk Assessment Process](#)

Where a subordinate policy is more specific than this one, the subordinate policy governs.

Exceptions

Any deviation from these policies (e.g., a temporary manual workaround during an incident) must be documented in the relevant policy or in the incident record, with a reason and a remediation date. Given the current team size, exceptions are self-approved by the founder and revisited at the next policy review.

Enforcement and review

This policy set is reviewed at minimum annually, and immediately after any material change to architecture, vendors, or team size. Non-compliance by any future employee or contractor is grounds for revoking system access pending review.